

Research Report: Common Network Security Threats



Author: Hasnat Haider Mir

Submitted to: Oasis InfoByte

Task 4: A Research Report on Attack Mechanics, Real-World Impact, and Mitigation Strategies

Deadline: 25 Aug, 2026.

Common Network Security Threats

A Research Report

Introduction

Modern organizations depend on interconnected networks for nearly every business function, from financial transactions to internal communication, which makes network security a foundational rather than optional discipline. As more devices, cloud services, and remote endpoints connect to corporate networks, the attack surface available to adversaries continues to expand. Attackers exploit weaknesses at every layer of the network stack from spoofing traffic sources to poisoning the very systems used to translate domain names into addresses often with financial theft, espionage, or simple disruption as the goal. Understanding how these attacks work, the damage they have caused in real incidents, and the concrete steps available to defend against them is essential for any network administrator responsible for protecting an organization's infrastructure.

1. DoS / DDoS Attacks

How it works: A Denial-of-Service (DoS) attack attempts to make a system or service unavailable to legitimate users, typically by overwhelming it with traffic or exhausting its resources (CPU, memory, bandwidth, or connection limits). A Distributed Denial-of-Service (DDoS) attack does the same thing but from many sources at once often thousands of compromised devices making it far harder to block by simply filtering a single IP address. Attackers frequently use botnets (networks of hijacked devices) or amplification techniques, where a small forged request to a vulnerable server triggers a much larger response directed at the victim.

Real-world example: In October 2016, the Mirai botnet was used to launch a DDoS attack against Dyn, a major DNS provider. The botnet was built from ordinary IoT devices such as routers, IP cameras, and DVRs that were compromised through factory-default credentials. The resulting attack made more than 50 major internet platforms including PayPal, Twitter, Reddit, Netflix, and Spotify temporarily unreachable across parts of North America and Europe. A related incident occurred in February 2018, when GitHub was hit with a 1.35 Tbps DDoS attack at the time the largest ever recorded using memcached servers abused via IP spoofing rather than a botnet at all.

Impact: DDoS attacks cause direct revenue loss from service downtime, damage to customer trust and brand reputation, and in some cases act as a smokescreen for a more targeted intrusion happening simultaneously. For DNS or infrastructure providers like Dyn, the disruption cascades to every downstream customer relying on that service.

Mitigation strategies:

Traffic filtering and rate limiting at the network edge or via a CDN/DDoS protection service (e.g., Cloudflare, Akamai) to absorb and filter malicious traffic before it reaches origin servers.

Redundant, geographically distributed infrastructure (multiple DNS providers, load-balanced servers) so a single point of failure cannot take the whole service offline.

IoT and endpoint hardening changing default credentials and disabling unnecessary remote services to reduce the pool of devices attackers can recruit into botnets.

2. Man-in-the-Middle (MITM) Attacks

How it works: In a MITM attack, an adversary secretly intercepts and potentially alters communication between two parties who believe they are communicating directly with each other. This can happen at the network level (e.g., ARP spoofing on a local network, rogue Wi-Fi access points) or at the application level (e.g., forging TLS/SSL certificates so encrypted traffic can be decrypted and re-encrypted by the attacker in transit).

Real-world example: In 2015, it was discovered that Lenovo had shipped consumer laptops preinstalled with malware called Superfish. The software installed its own self-signed root certificate into the operating system's trust store and used it to intercept and re-sign every HTTPS connection the user made, in order to inject advertisements. This meant an attacker capable of extracting Superfish's certificate which researchers demonstrated was trivial could forge valid-looking certificates for any site, including banks, without the browser raising a security warning.

Impact: MITM attacks silently break the confidentiality and integrity guarantees of encrypted connections, allowing attackers to steal login credentials, session tokens, and financial information, or inject malicious content into legitimate traffic without the user's knowledge.

Mitigation strategies:

Enforce HTTPS with HSTS (HTTP Strict Transport Security) and certificate pinning where feasible, so browsers refuse to fall back to unencrypted or improperly certified connections.

Use VPNs on untrusted networks (public Wi-Fi, hotel/airport networks) to encrypt traffic end-to-end regardless of what's on the local network.

Deploy network-level protections such as static ARP entries or Dynamic ARP Inspection on switches, and monitor for unexpected certificate authorities added to trust stores.

3. IP Spoofing

How it works: IP spoofing involves crafting network packets with a forged source IP address so the packet appears to originate from a trusted or different host than it actually does. Because IP itself does not

authenticate the sender, attackers can use spoofing to hide their identity, bypass IP-based access controls, or most commonly today to redirect the responses from a third-party server toward a victim in what's called a reflection/amplification attack.

Real-world example: The February 2018 GitHub DDoS attack is a clear example of IP spoofing in action. Attackers spoofed their source IP address to match GitHub's, then sent forged requests to exposed memcached servers, which responded with data amplified by more than 50,000 times the request size all directed at GitHub instead of the attacker. No botnet was needed; the spoofed source address alone was enough to redirect a flood of traffic at the victim.

Impact: Spoofing enables reflection/amplification DDoS attacks capable of reaching multi-terabit scale from a small amount of attacker bandwidth, and it also undermines any security control that trusts a packet's source IP for authentication or filtering decisions.

Mitigation strategies:

Ingress/egress filtering (BCP 38) at the ISP and network perimeter level, so routers drop packets whose source address doesn't match the expected range for that network segment.

Disable or restrict unauthenticated UDP-based services (like memcached, NTP, DNS resolvers) from being reachable on the public internet, since these are the servers abused for amplification.

Use authentication that doesn't rely on IP address alone e.g., IPsec, mutual TLS, or cryptographic session tokens for any service where source-IP trust is currently used as a security boundary.

4. DNS Poisoning / Spoofing

How it works: DNS poisoning (or cache poisoning) involves injecting forged DNS responses into a resolver's cache so that legitimate domain name lookups return an attacker-controlled IP address instead of the real one. This can happen by exploiting weaknesses in the DNS protocol itself (predictable transaction IDs/ports), by compromising a DNS registrar or authoritative server directly, or through local techniques like ARP spoofing that intercept and rewrite DNS traffic in transit.

Real-world example: Between late 2018 and 2019, two campaigns known as DNSpionage and Sea Turtle targeted DNS infrastructure across the Middle East, North Africa, and parts of Europe. DNSpionage compromised DNS records to redirect government and corporate traffic through attacker-controlled infrastructure to harvest credentials in transit, while Sea Turtle went further by compromising DNS registrars and providers directly to redirect victims to attacker-controlled nameservers prompting CISA to issue Emergency Directive 19-01 requiring federal agencies to audit DNS records and secure registrar accounts.

Impact: Successful DNS poisoning silently redirects victims to phishing or malware-hosting sites that can be visually identical to the real destination, enabling large-scale credential theft, malware distribution, or surveillance often without any visible sign to the end user that something is wrong.

Mitigation strategies:

Deploy DNSSEC to cryptographically sign DNS records, so resolvers can validate that a response actually came from the legitimate authoritative server.

Use DNS over HTTPS/TLS (DoH/DoT) to encrypt DNS queries in transit, preventing on-path attackers from intercepting or spoofing responses.

Harden registrar and DNS provider accounts with multi-factor authentication and registry locks, since several major incidents (including Sea Turtle) succeeded by compromising the account layer rather than the protocol itself.

Comparison Table:

Threat	Attack Vector	Who Is At Risk	Difficulty to Execute	Ease of Mitigation
DoS/DDOS	Traffic flooding, botnets, amplification	Any internet-facing service, especially DNS/hosting providers	Low–Medium (botnets/amplification tools widely available)	Medium (requires CDN/scrubbing services or redundant infra)
MITM	Rogue Wi-Fi, ARP spoofing, forged TLS certificates	Users on shared/untrusted networks; weak certificate validation	Medium (needs network position or a trusted software supply chain)	Medium (HTTPS/HSTS helps but needs consistent enforcement)
IP Spoofing	Forged source IP addresses in packets	Any service reachable by UDP-based reflectors; ISPs w/o egress filtering	Low (spoofing tools are simple)	Medium (BCP 38 filtering effective but not universal)
DNS Poisoning	Cache injection, registrar compromise, on-path interception	Anyone relying on unauthenticated DNS resolution	Medium–High (harder post-Kaminsky fixes; registrar compromise easier)	Medium–Hard (DNSSEC adoption inconsistent)

Conclusion: Key Takeaways for a Network Administrator

No single control is sufficient. Each threat above is best addressed with layered defenses filtering, encryption, authentication, and monitoring together rather than relying on any one technology to fully close the gap.

Trust boundaries need active enforcement, not assumptions. IP addresses, DNS responses, and even TLS certificates can all be forged; administrators should treat "who sent this" as something to verify cryptographically wherever possible, not something to assume from network position alone.

Basic hygiene prevents large-scale attacks. Many of the biggest incidents in this report Mirai, the GitHub memcached attack, Sea Turtle succeeded because of avoidable gaps: default credentials, exposed UDP services, and weak registrar account security. Patching, closing unnecessary exposed services, and enforcing strong authentication go a long way before more advanced defenses are even needed.

References

National Institute of Standards and Technology (NIST): Guide to DDoS Attacks, NIST SP 800-189 and related publications. <https://csrc.nist.gov/pubs/sp/800/189/final>

Cybersecurity and Infrastructure Security Agency (CISA): Understanding Denial-of-Service Attacks and Emergency Directive 19-01: Mitigate DNS Infrastructure Tampering. : <https://www.cisa.gov/news-events/news/understanding-denial-service-attacks>

MITRE ATT&CK: Network Denial of Service (T1498), Adversary-in-the-Middle (T1557), and related techniques. <https://attack.mitre.org/techniques/T1557/>

GitHub Engineering Blog: February 28th DDoS Incident Report (2018). <https://github.blog/news-insights/company-news/ddos-incident-report/>

Krebs on Security / industry incident coverage on the Mirai botnet, Lenovo Superfish, and DNS infrastructure attacks (Sea Turtle, DNSpionage). <https://krebsonsecurity.com/>